

[가답안 확인]

자격종목 및 등급(선택분야)
정보보안기사

2시간 30분

1 1150

성명



시스템보안

- ① 저장되는 필드 중 첫 번째에는 사용자 계정 UID가 있다.
- ② 사용자 계정과 패스워드가 저장되어 있다.
- ③ 사용자 계정 UID 값이 "0"이면 root이다.
- ④ 총 5개의 필드로 이루어져 있다.

① wtmp ② utmp
③ loginlog ④ sulog

① 개인정보 추가가 발견된 경우 ② 개인정보 수정이 발견된 경우
③ 개인정보 조회가 발견된 경우 ④ 개인정보 다운로드가 발견된 경우

유닉스 계열 파일시스템의 무결성을 점검하는데 높은 신뢰성을 제공하며, 파일의 스냅샷을 저장하고 이를 기준으로 변경된 파일정보를 관리자에게 보고하여 파일시스템의 변화를 모니터링한다.

① Nessus ② John the ripper
③ Tripwire ④ PAM

① gdb ② objdump
③ iptables ④ ltrace

- ① SQL(Structured Query Language) 인젝션을 통해 단순히 참 거짓을 판단할 수 있는 상황에서 실제 값을 파악하기 위한 공격이다.
- ② 별도의 인증없이 접근이 가능한 취약점을 이용한 악의적인 행위이다.
- ③ 특정한 암호를 풀기 위해 가능한 모든 값을 대입하는 것을 의미한다.
- ④ 웹 페이지의 입력값을 통해서 SQL 명령어를 주입하여 오동작을 일으키는 해킹 방법이다.

보안이 취약한 IoT 기기들을 해킹하여 악성코드에 감염시켜 좀비 네트워크를 만들고 해커의 명령을 받아 DDoS 공격을 발생시켰다.

① 워너크라이 ② 익스플로잇
③ 미라이 봇넷 ④ 제로데이 공격

- ① 운영체제에 내재된 결함으로 인해 발생할 수 있는 각종 해킹으로부터 보호하기 위해 보안 기능이 통합된 보안 커널을 추가로 이식한 운영체제이다.
- ② 기본으로 열려있는 취약한 서비스를 모두 차단한다.
- ③ 계정 관리 및 서비스 관리에 있어 좀 더 나은 보안 체계를 가지고 운영될 수 있도록 한다.
- ④ 보안 운영체제는 시스템에서 일어나는 프로세스의 활동이 보안 정책에 위반되지 않는지를 검사하지만 시스템 성능에는 아무런 영향이 없다.

- ① `nmap -sS [target]` : 대상에서 열려있는 포트를 확인하기 위해 TCP SYN 스캔을 사용한다.
- ② `nmap -sU [target]` : 대상에서 열려있는 포트를 확인하기 위해 UDP 스캔을 사용한다.
- ③ `nmap -O [target]` : 대상의 운영체제를 확인하려고 시도한다.
- ④ `nmap -v [target]` : 대상에 대한 운영체제, 소프트웨어 버전 및 기타 정보를 확인하려고 시도한다.

① 입출력 포트를 이용한 공격 ② 역공학을 통한 버스 프루빙 공격
③ 펌웨어 다운그레이드 공격 ④ 부채널 공격

- ① `nmap -sP [target] --disable-arp-ping`
- ② `nmap -sn [target] --disable-arp-ping`
- ③ `nmap -sP -PB [target] --disable-arp-ping`
- ④ `nmap -sP -PS [target] --disable-arp-ping`

- ① 백 트랙(Back track)
- ② 칼리 리눅스(Kali linux)
- ③ 미고(MeeGo)
- ④ 페럿 리눅스(Parrot linux)

- ① 최근 로그인 정보
- ② 사용자 계정
- ③ 사용자명
- ④ 사용자 계정 홈 디렉터리

SSI 인젝션 취약점 점검을 위하여 사용자가 입력 가능한 파라미터 값에 `<!--#echo var="DOCUMENT_ROOT" -->`를 삽입하여 전송 후 반환되는 페이지에 사이트의 ()가 표시되는지 확인한다.

① 홈 디렉터리 ② 유저 디렉터리
③ 기본 웹 사이트 ④ 어드민 디렉터리

15. 다음 중 Linux 시스템의 로그인 시 로그인 메시지와 관련된 설정 파일로 옳은 것은?

o /etc/(㉠) : telnet 또는 ssh로 shell 접속 시 로그인이 성공되었을 때 보이는 메시지
 o /etc/(㉡) : telnet으로 shell 접속 시 사용자가 로그인할 때 로그인하기 전에 출력되는 메시지
 o /etc/(㉢) : IDC센터에 있는 Real 서버에 로컬로 KVM을 붙여서 확인했을 때 출력되는 메시지, 로컬 로그인 시 로그인 전 출력되는 메시지 설정

- ① ㉠ : issue.net, ㉡ : issue, ㉢ : motd
 ② ㉠ : motd, ㉡ : issue.net, ㉢ : issue
 ③ ㉠ : issue, ㉡ : issue.net, ㉢ : motd
 ④ ㉠ : issue, ㉡ : motd, ㉢ : issue.net

16. 유닉스 환경에서 다음 문장과 같은 기능을 수행하는 로깅 도구는?

syslog.conf 파일 설정에 따라 동작하는 로그 때문에 커널 로그, 메시지(messages) 로그, secure 로그, 크론 로그, 부팅 로그 및 메일 로그, 네임서버 로그, ftp 로그 등의 로그를 관리할 수 있다.

- ① tripwire ② sysloged
 ③ ghost ④ glog

17. 다음 중 칼리 리눅스(Kali Linux)에서 기본으로 제공하는 도구인 버프 스위트(Burp Suite)에서 무차별 대입 공격(Brute Force Attack) 및 퍼징(Fuzzing) 공격과 같은 자동화된 사용자 지정 공격을 수행할 수 있는 기능으로 옳은 것은?

- ① Scope ② Intruder
 ③ Intercept ④ History

18. 다음 문장에서 괄호 안에 들어갈 용어로 옳은 것은?

방화벽(Firewall)은 외부로부터의 불법적인 접근이나 해커의 공격으로부터 내부 네트워크를 방어하기 위해 내부 네트워크와 외부 네트워크 사이의 통로에 설치된다. ()은/는 인터넷 쪽과 내부 네트워크 쪽에 패킷 필터링 라우터를 설치하고 그 라우터들 사이에 배스천 호스트를 설치하는 구성을 가진다.

- ① 듀얼-홈드 게이트웨이(Dual-homed gateway)
 ② 스크린드 서브넷 게이트웨이(Screened subnet gateway)
 ③ 스크린드 호스트 게이트웨이(Screened host gateway)
 ④ 배스천 호스트(Bastion host)

19. 윈도우에서 관리 목적상 기본적으로 공유되는 폴더 중 Null Session 공유 취약점을 가지고 있는 것은?

- ① C\$ ② Print\$
 ③ IPC\$ ④ ADMIN\$

20. 힙 오버플로우 공격에 대한 설명으로 틀린 것은?

- ① 프로그래머가 malloc()과 같은 함수를 이용한다.
 ② 힙 영역을 오버플로우시켜 특정 코드를 실행하여 공격한다.
 ③ 버스를 통해 전달되는 중요 정보를 엿보고 가로채는 공격이다.
 ④ 프로그램이 실행되면서 메모리를 동적으로 할당하는 영역을 이용한다.

네트워크보안

21. 정해진 시간 내 메시지의 모든 단편이 수신되지 않았을 때 해당하는 ICMP(Internet Control Message Protocol) 오류 메시지는?

- ① 목적지 도달 불가능(destination-unreachable)
 ② 시간 경과(time-exceeded)
 ③ 매개변수 문제(parameter-problem)
 ④ 발신지 억제(source-quench)

22. 다음 중 라우팅 프로토콜에 대한 설명으로 틀린 것은?

- ① RIP(Routing Information Protocol)은 소규모 네트워크에 적합하다.
 ② RIP은 전통적인 Distance Vector Algorithm을 사용한다.
 ③ OSPF(Open Shortest Path First) 프로토콜은 수평적 구조로 네트워크 구성이 가능하여 대규모 네트워크에 적합하다.
 ④ IGRP(Interior Gateway Routing Protocol)은 자율 시스템 내의 라우팅 데이터를 교환할 목적으로 사용하기 위해 개발되어 네트워크의 규모가 크고 복잡하더라도 안정적으로 움직일 수 있게 되어있다.

23. 다음 중 Windows 운영체제의 'net share' 명령어의 설명으로 틀린 것은?

- ① 'net share' 명령어는 공유 자원의 목록을 보여주거나 공유를 생성하고 삭제할 수 있다.
 ② 'net share' 명령어를 사용하여 공유의 권한을 변경할 수 있다.
 ③ 'net share' 명령어는 공유에 연결된 클라이언트의 수를 확인할 수 있다.
 ④ 'net share' 명령어를 사용하여 공유된 폴더의 암호화 설정을 변경할 수 있다.

24. 다음 문장에서 설명하는 것은?

서로 다른 운영체제(OS) 간의 자원 공유를 위해 이용하는 서버로 같은 네트워크 내 연결된 PC는 서로 운영체제가 달라도 네트워크로 파일을 주고받고 자원을 공유할 수 있도록 하는 기법

- ① Samba
 ② DNS(Domain Name System)
 ③ RPC(Remote Procedure Call)
 ④ NIS(Network Information Service)

25. 다음 문장에서 설명하는 공격으로 옳은 것은?

공격자는 공격용 IP 패킷을 위해 두 개의 fragment를 생성한다. 첫 번째 fragment에서는 필드 필터링 장비에서 허용하는 http(TCP 80) 포트와 같은 포트번호를 가진다. 그리고 두 번째 fragment에서는 offset을 아주 작게 조작해서 fragment들이 재조합될 때 두 번째 fragment가 첫 번째 fragment의 일부분을 덮어쓰도록 한다. 일반적으로 공격자들은 첫 번째 fragment의 포트번호가 있는 부분까지 덮어씌운다. IDS에서는 첫 번째 fragment는 허용된 포트번호이므로 통과시키고 두 번째 fragment는 이전에 이미 허용된 fragment의 ID를 가진 fragment이므로 역시 통과시킨다. 이 두 개의 fragment가 목적지 서버에 도달하여 재조합되면 첫 번째 fragment의 포트 번호는 두 번째 fragment의 포트 번호로 overwrite되고 TCP/IP 스택은 이 패킷이 필터링되어야 할 포트의 응용프로그램에 전달한다.

- ① Tiny fragment 공격
 ② Fragment Overlap 공격
 ③ IP Fragmentation을 이용한 서비스거부 공격 - Jolt
 ④ IP Fragmentation을 이용한 서비스거부 공격 - Teardrop

26. 다음 중 DDoS(Distributed Denial of Service) 공격의 대응 방안으로 틀린 것은?

- ① 방화벽을 설치하여 내부 네트워크로 패킷이 진입하는 것을 차단한다.
 ② IDS를 통해 공격을 탐지하고 대응한다.
 ③ Zombie 톨을 사용하여 내부 DDoS 톨을 탐색하고 제거한다.
 ④ 호스트의 서비스별 대역폭을 증가시킨다.

27. 다음 중 NMAP 포트 스캔에 대한 설명으로 틀린 것은?

- ① TCP Connect Scan : 대상 포트에 대해 3-Way Handshaking을 정상적으로 통신하는 방식으로 정상적이면 포트가 열려있다고 판단할 수 있다.
 ② TCP FIN Scan : 대상 포트에 FIN 패킷을 전송하는 방식으로 응답받으면 포트가 열려있다고 판단할 수 있다.
 ③ TCP X-MAS Scan : 대상 포트에 FIN, URG, PSN 플래그가 모두 설정된 패킷을 전송하는 방식으로 응답받으면 포트가 닫혀있다고 판단할 수 있다.
 ④ TCP Null Scan : 대상 포트에 NULL 패킷을 전송하는 방식으로 응답받으면 포트가 닫혀있다고 판단할 수 있다.

28. hosts 파일을 통해 도메인 이름에 대한 IP 주소 작성 시 대응할 수 있는 스푸핑 공격은?

- ① DNS 스푸핑 ② ARP 스푸핑
③ IP 스푸핑 ④ 이메일 스푸핑

29. 다음 문장은 IP 스푸핑 보안 대책에 대한 설명이다. 괄호 안에 들어갈 내용으로 옳은 것은?

(㉠) 관계를 이용한 IP 스푸핑 방지 대책으로 가장 좋은 보안 대책은
(㉡)을(를) 사용하지 않는 것이다. 불가피하게 사용할 경우 MAC 주소를
(㉢)으로 지정한다.

- ① ㉠ : NAT, ㉢ : dynamic
② ㉠ : NAT, ㉢ : static
③ ㉠ : 트러스트, ㉢ : dynamic
④ ㉠ : 트러스트, ㉢ : static

30. 다음은 리눅스 시스템의 '/var/log/messages' 파일 내 로그 내용이다. 다음 중 해당 로그를 통해 추정할 수 있는 공격으로 옳은 것은?

Sep 21 16:55:08 Security kernel: device eth0 entered promiscuous mode
Sep 21 16:55:34 Security kernel: device eth0 left promiscuous mode

- ① Sniffing ② Spoofing
③ DoS Attack ④ Noise Jamming

31. 다음 중 스니핑에 사용되는 툴로 틀린 것은?

- ① DSniff ② PGP
③ TCP Dump ④ fragroute

32. 다음 중 NFS(Network File System) 서비스 취약점 발견에 따른 조치사항이 아닌 것은?

- ① NFS 서비스 중지
② 인가되지 않은 시스템을 umount 함
③ 네트워크상의 파일시스템을 mount 함
④ nfsd, statd, lockd 중지

33. 다음 중 HTTPS(HyperText Transfer Protocol Secure)의 특징으로 틀린 것은?

- ① 데이터를 주고받는 과정에 SSL/TLS 암호화를 사용하여 데이터를 암호화한다.
② HTTPS는 공격자가 중간에 스니핑을 하기 어렵다.
③ HTTPS는 HTTP의 처리속도를 빠르게 향상시켰다.
④ 무결성을 사용하여 데이터가 전송 중에 변경되지 않았는지 확인할 수 있다.

34. 다음 문장에서 설명하는 것은?

수십만 시스템에 설치된 공공 도메인의 공개 소스 IDS이다. 일반적인 탐지 인터페이스인 libpcap을 사용한다. 일반적으로 새로운 공격이 나타난 후 수 시간 내에 공격 시그니처를 작성·배포하고 세계 곳곳의 수십만 시스템에 다운로드 된다. 네트워크 관리자는 이 공개 소스 IDS에 있는 기존 시그니처를 수정하거나 새로 만들어 자기 조직에 맞는 시그니처를 생성할 수 있다.

- ① Anomaly-based IDS ② Snort
③ Signature-based IDS ④ IPS

35. 다음은 네트워크 트래픽을 분석하던 중 발견한 로그의 일부이다. 해당 로그의 공격 방식과 목표에 대한 설명으로 옳지 않은 것은?

[06/Jul/2023:00:00:01 +0900] "Source:192.168.0.1 Dest:192.168.0.2 Port:22"
[06/Jul/2023:00:00:01 +0900] "Source:192.168.0.1 Dest:192.168.0.2 Port:23"
[06/Jul/2023:00:00:01 +0900] "Source:192.168.0.1 Dest:192.168.0.2 Port:80"
[06/Jul/2023:00:00:01 +0900] "Source:192.168.0.1 Dest:192.168.0.2 Port:443"
[06/Jul/2023:00:00:01 +0900] "Source:192.168.0.1 Dest:192.168.0.2 Port:3306"

- ① 해당 로그는 공격자가 포트 스캐닝을 시도했음을 나타낸다. 공격자는 서버의 개방된 포트를 찾아 추가적인 공격의 기반이 될 정보를 수집하려고 했다.
② 공격자는 TCP/IP 네트워크에서 가장 일반적으로 사용되는 포트를 스캔했다. 이 포트들은 각각 SSH, Telnet, HTTP, HTTPS, MySQL을 위한 것이다.
③ "Source:192.168.0.1 Dest:192.168.0.2 Port:3306" 로그는 공격자가 MySQL 데이터베이스 서버에 접근 가능한지 확인하려는 시도를 보여준다.
④ 이 로그는 공격자가 DoS 공격을 시도했음을 나타낸다.

36. 다음 중 사용자 인증과 무결성 검사가 핵심이 적용된 기술로 단말(End Point)에 대한 통합위협관리 시스템을 지칭하는 것은?

- ① Firewall
② UTM(Unified Threat Management)
③ DRM(Device Relationship Management)
④ NAC(Network Access Control)

37. UTM(Unified Threat Management)에 대한 설명으로 틀린 것은?

- ① UTM은 다양한 보안 솔루션을 하나의 장비에 탑재하여 운영하는 All-in-One 통합보안 솔루션이다.
② 보안 정책 적용이 개별적으로 이루어지므로 전문가의 운영이 필요하다.
③ 다양한 보안 기능을 하나의 솔루션에 통합하여 복합 해킹 위협에 효과적으로 대응하는 것에 목적을 두고 있다.
④ 보안 정책, 필터링 시그니처를 통합 관리하여 일관성과 운영 효율성을 제공한다.

38. 다음 문장의 스노트(snort) 를 예시에 대한 설정으로 옳은 것은?

모든 네트워크 대역에서 텔넷(Telnet)으로 접속하는 패킷 중 첫 바이트부터 14번째 바이트까지 'anonymous'가 포함된 트래픽에 대해서 'Dangerous' 메시지로 경고한다.

- ① alert tcp any any -> any 23 (msg:"Dangerous"; content:"anonymous"; depth:14; sid:1;)
② alert tcp any any -> any 80 (msg:"Dangerous"; content:"anonymous"; depth:14; sid:1;)
③ alert tcp any any -> any 23 (msg:"Dangerous"; content:"anonymous"; distnace:14; sid:1;)
④ alert tcp any any -> any 80 (msg:"Dangerous"; content:"anonymous"; distnace:14; sid:1;)

39. IPsec을 이용하여 VPN 구축 시 IKE(Internet Key Exchange)에서 작성하는 정책을 IPsec SA라 한다. 다음 중 SA 내용에 포함되지 않는 것은?

- ① 인캡슐레이션(Encapsulation) 방식
② 데이터 암호화 방식
③ 무결성 확인 알고리즘
④ 보호 대상 네트워크

40. 다음 중 Sendmail의 로그 형식에서 관련 지시자에 대한 정의로 틀린 것은?

- ① Stat : 메시지 전달 상태
- ② Proto : 수신 시 사용된 프로토콜
- ③ Class : 메시지 식별자
- ④ Delay : 메시지 발신에서 수신까지 걸린 시간

어플리케이션보안

41. 다음 중 FTP(File Transfer Protocol)에서 데이터 전송 모드에 관한 설명으로 옳은 것은?

- ① default는 active 모드이며, passive 모드로의 변경은 FTP 서버가 결정한다.
- ② default는 active 모드이며, passive 모드로의 변경은 FTP 클라이언트가 결정한다.
- ③ default는 passive 모드이며, active 모드로의 변경은 FTP 서버가 결정한다.
- ④ default는 passive 모드이며, active 모드로의 변경은 FTP 클라이언트가 결정한다.

42. 다음은 FTP(File Transfer Protocol) 서비스의 패시브모드(Passive Mode)로 설정하여 서버에 명령을 전송한 응답이다. 데이터 전송을 위한 서버의 포트 번호는?

227 Entering Passive Mode (1,222,15,150,100,16)

- ① 20 ② 21
③ 25616 ④ 10016

43. 다음 중 메일 서비스 운영 시 메일 수신이 거부되거나 스팸메일로 분류되는 경우 확인 또는 조치할 수 있는 사항으로 틀린 것은?

- ① White Domain을 등록한다.
- ② ISP의 클린존 서비스를 이용한다.
- ③ SPF(Sender Policy Framework) Record에 등록된 발신자인지 확인한다.
- ④ RBL(Real-Time Blocking List)을 확인하고 차단되어 있으면 차단해제를 신청한다.

44. 다음 문장에서 설명하는 메일 클라이언트 보안은 무엇인가?

- 사용자가 작성한 이메일의 내용과 첨부되는 파일을 암호화하여 이메일 수신자만이 그 내용을 볼 수 있도록 하는 기밀성을 제공한다.
- 전자서명 기능을 제공하여 송신자라고 주장하는 사용자와 이메일의 실제 송신자가 동일한가를 확인한다.
- 공개키를 4,096비트까지 생성할 수 있다.

- ① 필터링 ② 첨부 파일
③ PGP ④ 악성 스크립트

45. 다음 중 애플 iOS 운영체제 기반의 앱을 개발하고 분석할 수 있는 개발도구로 옳은 것은?

- ① Xcode ② adb
③ apktool ④ dex2jar

46. 다음 문장에서 설명하는 웹 서비스 공격 유형은?

- 게시판의 글에 원본과 함께 악성코드를 삽입하여 글을 읽을 경우 악성코드가 실행되도록 하여 클라이언트의 정보를 유출하는 클라이언트에 대한 공격

- ① XSS(Cross Site Scripting)
- ② 쿠키/세션 위조
- ③ SQL Injection
- ④ CSRF(Cross Site Request Forgery)

47. 다음과 같은 소스 코드를 작성하는 기법은?

```
function __(_:int,__:int=0,___:int=6):Boolean{return(__(+___/___)*(
_+___/___)<=_?__(_,+___/___,___):_==_?_:_:
_<_-(+___+___)/_?_/_:_(___+___)=_=_|_|_%(_*_/(+___))
==_=_|_|_%=_==_=_?_/_-_-/_:___<_?
_%(_-_-/_)==_/_-_-/_?_==_=_-_-/_:_(+___/___)==_+
_-_-_-?_==_+___/___:
___(____,____+(*_***(+___+___)+_**_*+(+___)*_**_)/_/___):
_}
```

- ① 암호화 ② 난독화
③ 캡슐화 ④ 모듈화

48. 다음 중 DNSSEC(DNS Security Extensions)으로 대응이 가능한 공격유형은?

- ① 파밍(캐시 포이즈닝) ② 피싱
- ③ DDoS 공격 ④ 웹바이러스에 의한 호스트 정보 변조

49. 다음 문장에서 설명하는 DNS(Domain Name System) 레코드는?

DNS 서버를 가리키며, 각 도메인에 적어도 한 개 이상 있어야 한다.

- ① A ② MX
③ NS ④ CNAME

50. 다음과 같은 내용이 규정되어 있는 표준은?

카드 정보 해킹 및 도난, 분실 사고로부터 고객의 신용카드 정보 유출을 막기 위해 여러 글로벌 신용카드사에서 만든 신용카드 데이터 보안 표준으로 보안 시스템에 대한 기술 요구 사항, 개발 과정 및 운영 시 보안 요구 사항, 카드 소유자의 데이터 암호화, 정보보호 정책 등이 규정

- ① PCI-DSS(Payment Card Industry – Data Security Standard)
- ② SET(Secure Electronic Transaction)
- ③ PKI(Public Key Infrastructure)
- ④ ISMS(Interactive Short Message Service)

51. 다음 문장에서 설명하는 기술은?

파일을 분석하여 악성코드 등 문제 있는 해당 영역만을 제거하고 파일을 재조합하여 무해한 파일로 제공하는 보안기술이다.

- ① CDR(Content Disarm & Reconstruction)
- ② EDR(Endpoint Detection & Response)
- ③ NFV(Network Function Virtualization)
- ④ SDN(Software Defined Network)

52. 다음 중 안드로이드 기기에서 데이터를 안전하게 처리하는 방법으로 틀린 것은?

- ① 전송중인 데이터의 경우 민감도와 관계없이 모든 데이터 전송에 TLS(Transport Layer Security)를 사용한다.
- ② 민감한 정보를 다른 앱으로 전달해야 한다면 명시적인 인텐트를 사용한다. 일회성 데이터 액세스 권한을 부여하여 다른 앱의 액세스를 더 엄격하게 제한한다.
- ③ Logcat 메시지 또는 앱의 로그 파일에 민감한 정보를 포함하지 않는다.
- ④ 민감한 정보가 포함된 파일은 SDcard와 같은 외부 저장소에 배치한다.

53. 다음 포맷 스트링 주요 함수 중 인자값을 포맷 스트링으로 지정한 버퍼(Buffer)에 출력하는 함수로 옳은 것은?

- ① sprintf ② vprintf
③ fprintf ④ printf

54. 다음 공개소프트웨어 점검 도구 중 지원언어가 다른 것은?

- ① WAP ② Pixy
③ PHP-Sat ④ UNO

55. DBMS(Database Management System) 기본 계정 디폴트 패스워드 및 권한 정책을 변경하지 않을 경우 비인가자가 인터넷을 통해 DBMS 기본 계정의 디폴트 패스워드를 획득하여 디폴트 패스워드를 그대로 사용하고 있는 DB에 접근하여 DB 정보를 유출할 수 있는 위험이 존재한다. 다음 중 oracle 설치 시 생성되는 디폴트 계정과 디폴트 패스워드의 연결이 틀린 것은?

- ① sys - changeon_install
② scott - tiger
③ system - manage
④ dbnmp - dbnmp

56. 다음 중 데이터베이스 보안을 위한 설정 및 명령어의 의미로 틀린 것은?

- ① alter login sa with password='test_password';
=> sa 계정 암호 변경
② EXEC sp_droprvrolemember 'user01', 'sysadmin';
=> user01 및 sysadmin 계정을 삭제
③ CREATE PROFILE grace_5 LIMIT;
FAILED_LOGIN_ATTEMPTS 3
=> lock걸리기 전까지 패스워드 실패 3번까지만 가능
④ CREATE PROFILE grace_5 LIMIT;
PASSWORD_LOCK_TIME 1
=> 암호 입력 실패하였을 경우 1일동안 해당 계정에 대해 lock 유지

57. 다음 전자상거래 보안 중 SSL record 프로토콜의 동기 암호화 알고리즘을 이용하여 압축하는 알고리즘으로 틀린 것은?

- ① IDEA ② RCs-40
③ DES-40 ④ WPKI

58. 다음 문장에서 설명하는 핀테크(FinTech) 기술과 관련된 것은?

고객 신용카드 거래를 분석해 평소와 다른 의심 거래 이상 징후가 있을 때 회원과 통화하거나 확인 과정을 통해 사고를 예방하는 시스템을 말한다. 예를 들어 출국 기록이 없는데 갑자기 해외에서 카드를 사용할 경우 이를 발견하는 등 금융거래정보를 중심으로 카드사 고객의 소비 스타일 및 각종 패턴까지 분석하는 기능을 제공한다.

- ① CNP(Credit-Not-Present)
② PCI-DSS(Payment Card Industry-Data Security Standard)
③ FDS(Fraud Detection System)
④ EMV(Europay, Mastercard, Visa)

59. 다음 문장에서 설명하는 내용에 대한 조치 방법으로 틀린 것은?

웹 사이트에 중요정보(개인정보, 계정정보, 금융정보 등)가 노출되거나 에러 발생 시 과도한 정보(어플리케이션 정보, DB 정보, 웹 서버 구성 정보, 개발 과정의 코멘트 등)가 노출될 경우 공격자들의 2차 공격을 위한 정보로 활용될 수 있다.

- ① 사용자가 주민등록번호 뒷자리, 비밀번호 입력 시 별표 표시하는 등 마스킹 처리를 하여 주변 사람들에게 노출되지 않도록 한다.
② 웹페이지를 운영 서버에 이관 시 주석은 모두 제거하여 이관한다.
③ 중요정보(개인정보, 계정정보, 금융정보 등)를 HTML 소스에 포함하지 않도록 한다.
④ 로그인 실패 시 반환되는 에러 메시지는 회원을 위해 특정 ID의 가입 여부를 식별할 수 있게 구현한다.

60. 다음은 HTTP Request 메시지의 일부이다. 이를 통해 알 수 없는 것은?

```
GET /index.html HTTP/1.1
User-Agent: Mozilla/4.0 (compatible; MSIE5.01; Windows NT)
Host: www.test.com
Accept-Language: en-us
Accept-Encoding: gzip, deflate
Connection: Keep-Alive
```

- ① 클라이언트가 요청한 파일 이름 ② 클라이언트가 요청한 방식
③ 서버의 운영체제 종류 ④ 서버의 DNS 이름

정보보안일반

61. 다음 중 RADIUS(Remote Authentication Dial In User Services) 서버가 사용자 인증을 하는 프로토콜이 아닌 것은?

- ① PAP ② CHAP
③ EAP ④ NTP

62. 다음 중 정보보호 통제 분야 중 '정보보호 정책'에 대한 통제 목표가 아닌 것은?

- ① 정책의 승인 및 공포 ② 정책의 체계
③ 정책의 작성방법 ④ 정책의 유지 관리

63. 다음 중 주체와 객체의 수가 많거나 이들이 빈번하게 변경될 경우 접근통제 구현이 어려운 방법은?

- ① 접근통제 매트릭스(Access Control Matrix)
② 접근통제 목록(Access Control List)
③ 접근통제 자격(Access Control Capability)
④ 임의적 접근통제(Discretionary Access Control)

64. 다음 중 공개키 교환방식에 대한 설명으로 틀린 것은?

- ① 서로 다른 암호화 키와 복호화 키를 사용한다.
② 대칭키 알고리즘에 비해 속도가 느리다.
③ 대표적인 알고리즘으로는 RSA가 있다.
④ 공개키 방식의 암호화 키와 복호화 키는 비공개되어 있다.

65. SET(Secure Electronic Transaction)에서 도입된 기술로 고객의 구매 정보는 은행이 모르게 하고, 지불 정보는 상점이 모르게 하도록 사용하는 서명 방식은?

- ① 은닉 서명(Blind Signature)
② 그룹 서명(Group Signature)
③ 수신자 지정 서명(Nominative Signature)
④ 이중 서명(Dual Signature)

66. 다음 중 블라인드 디지털 서명에 대한 설명으로 틀린 것은?

- ① 문서의 내용을 보여주지 않고 서명을 받아 검증하는 방식이다.
② 특허에 대한 공증을 받는 분야에서 활용될 수 있다.
③ 서명자에게 불리한 내용에 대한 서명을 하도록 악용될 수 있다.
④ 블라인드 디지털 서명은 실제로 구현될 수 없다.

67. 다음 문장에서 설명하는 암호 알고리즘은?

o 암호화는 DES와 유사한 변형된 Feistel 구조이다.
o 1999년 한국인터넷진흥원과 국내 암호전문가들이 함께 개발한 알고리즘으로 인터넷, 전자상거래 등에서 공개될 경우 민감한 영향을 끼칠 수 있는 중요정보 및 개인정보를 보호하기 위한 대칭키 암호 알고리즘이다.

- ① HIGHT ② ARIA
③ LEA ④ SEED

68. 다음 중 RSA(Rivest-Shamir-Adleman) 암호화 알고리즘에 발생할 수 있는 공격에 대한 설명으로 틀린 것은?

- ① 수학적 공격(Mathematical Attack)은 두 개의 소수 곱을 인수분해하고자 하는 공격으로 개인키 d 의 비트 수가 클수록 안전하다.
- ② 시간 공격(Timing Attack)은 복호화 알고리즘의 실행 시간에 의존하는 공격으로 Random Delay라는 방법을 이용하여 방어한다.
- ③ 선택 암호문 공격(Chosen Ciphertext Attack)은 RSA 알고리즘이 지닌 임의의 데이터 송신 시 암호문으로 간주하여 회신하는 기능을 이용하는 공격으로 OAEP(Optimal Asymmetric Encryption Padding)라는 알고리즘을 이용하여 방어할 수 있다.
- ④ 재생 공격(Replaying Attack)은 암호화하여 송신한 데이터를 보관하고 있다가 일정 시간 경과 후 재전송하여 비인가 접근을 시도하는 공격으로 방어할 수 없다.

69. CTR 모드에서 암호문 블록의 한 비트가 전송 도중에 다른 비트로 변경되었지만 암호문 블록의 길이 자체는 변동이 없다고 한다면 복호화 과정에서 몇 개의 평문 블록에 영향을 미치는가?

- ① 1 ② 2
③ 3 ④ 4

70. 다음 중 타원곡선암호(ECC)에 대한 설명으로 틀린 것은?

- ① 대표적인 비대칭키 암호시스템이다.
- ② 동일한 수준의 보안성을 제공하면서 키의 길이는 짧다.
- ③ 타원곡선에서 소인수분해의 문제를 기초로 한다.
- ④ 다양한 암호방식 설계와 H/W 및 S/W의 구현이 용이하다.

71. 다음 SHA 해시함수 중 블록길이가 1,024인 함수는?

- ① SHA-224, SHA-256 ② SHA-1, SHA-224
③ SHA-256, SHA-384 ④ SHA-384, SHA-512

72. 다음 중 GMAC(Galois Message Authentication Code)와 GCM(Galois/Counter Mode)에 대한 설명으로 틀린 것은?

- ① GCM은 인증 암호의 일종이다.
- ② AES와 같은 128비트 블록암호를 CTR 모드로 이용하여 MAC값을 얻는다.
- ③ CTR 모드는 1씩 증가하는 숫자를 암호화하기 때문에 각 블록을 직렬 처리하여 실행 속도를 높일 수 있다.
- ④ CTR 모드와 MAC값 생성에 공통 키를 사용하기 때문에 키 관리가 편리하다.

73. 암호 프로토콜을 이용한 디바이스 인증 중 RC4 기반의 WEP(Wired Equivalent Privacy) 기술에 대한 취약점을 해결하기 위한 인증 기술은?

- ① 인증서 인증
- ② IEEE 802.11i 인증
- ③ Challenge-Response 인증
- ④ Kerberos 인증

74. 리눅스 커널 내부의 네트워크 관련 프레임워크인 리눅스 방화벽은?

- ① iptables ② ufw
③ nftables ④ netfilter

75. 인증기관(CA : Certification Authority)을 이용하여 철수의 공개키를 얻으려 할 때, 얻은 철수의 공개키가 가짜가 아니라는 것을 확인할 수 있는 이유는 무엇인가?

- ① 철수의 인증서는 위조할 수 없는 CA의 개인키로 서명되어 있기 때문이다.
- ② 철수의 인증서는 인증기관이 신분 확인을 통해 검증했기 때문이다.
- ③ 철수의 인증서는 세션키를 통해 안전하게 암호화되었기 때문이다.
- ④ 철수의 인증서는 통제된 신뢰받는 센터를 통해 전달되었기 때문이다.

76. 다음 중 전통적 서명과 디지털 서명의 차이점에 대한 내용으로 틀린 것은?

- ① 전통적 서명은 문서에 포함되지만 디지털 서명은 분리되어 있다.
- ② 전통적 서명은 한 사람이 많은 문서에 동일한 서명이 가능하지만 디지털 서명은 불가능하다.
- ③ 전통적 서명은 복사본이 원래 문서와 구별되지만 디지털 서명은 복제 시 구별할 수 없다.
- ④ 전통적 서명은 서명과 문서 사이에 1:n 관계가 성립하지만 디지털 서명은 1:1 관계이다.

77. RSA(Rivest-Shamir-Adleman) 알고리즘에서 안전성을 높이기 위한 조건으로 틀린 것은?

- ① p 와 q 는 거의 같은 크기의 소수이어야 한다.
- ② $p-1$ 과 $q-1$ 은 큰 소수를 인수로 가져야 한다.
- ③ p 와 q 를 곱한 N 은 200자리 이상의 소수이어야 한다.
- ④ $p-1$ 과 $q-1$ 의 최대공약수는 작아야 한다.

78. 192비트 키를 사용하는 AES 알고리즘의 복호화 과정에서 12라운드에는 포함되지 않는 함수는?

- | | |
|----------------|-----------------|
| ① AddRoundKey | ② InvSubBytes |
| ③ InvShiftRows | ④ InvMixColumns |

79. 다음 중 HMAC(Hash-based Message Authentication Code)에 대한 설계 목적의 설명으로 틀린 것은?

- ① 내장된 해시함수를 손쉽게 교체할 수 있어야 한다.
- ② 사용되는 해시함수를 손쉽게 구할 수 있어야 한다.
- ③ 제공되는 해시함수를 목적에 맞게 변경하여 사용할 수 있어야 한다.
- ④ 해시함수의 원래의 성능을 거의 유지할 수 있어야 한다.

80. 다음 문장에서 설명하는 것은?

ElGamal 디지털 서명 구조의 문제점은 생성되는 서명의 길이가 2048비트를 넘어간다는 것이다. 이를 해결하기 위해 제안된 방식으로 ElGamal을 기반하고 있지만 서명의 길이가 짧은 디지털 서명구조이다.

- ① Schnorr 디지털 서명 구조 ② RSA 디지털 서명 구조
③ ECDSA ④ DSS

정보보안관리및법규

81. 다음 문장에서 괄호 안에 들어갈 용어로 옳은 것은?

정보보호 및 개인정보보호 관리체계의 수립 및 운영 활동 전반에 의사 결정권이 있는 ()가 이루어질 수 있도록 보고 및 의사 결정 등의 책임과 역할을 문서화하여야 한다.

- ① 경영진의 참여 ② 현업 및 관련부서의 참여
③ 정보보호 담당자의 참여 ④ 정보보호 관리자의 참여

82. 정보보호 조직구성 시 고려해야 할 사항으로 옳지 않은 것은?

- ① 정보보호 최고책임자 및 개인정보 보호책임자의 업무를 지원하고 조직의 정보보호 및 개인정보보호 활동을 체계적으로 이행하기 위해 전문성을 갖춘 실무조직을 구성하여 운영하여야 한다.
- ② 정보보호 및 개인정보보호 위원회를 구성할 경우 반드시 임원 등 경영진을 포함하지 않고 실무부서의 장으로만 구성하여 실질적이고 효율적인 협의체를 운영하여야 한다.
- ③ 조직 전반에 걸친 중요한 정보보호 및 개인정보보호 관련 사항에 대하여 검토, 승인 및 의사 결정을 할 수 있는 위원회를 구성하여 운영하여야 한다.
- ④ 전사적 정보보호 및 개인정보보호 활동을 위하여 정보보호 및 개인정보보호 관련 담당자 및 부서별 담당자로 구성된 실무 협의체를 구성하여 운영하여야 한다.

83. 다음 중 정보통신기반 보호법에 따른 정보통신기반보호위원회의 심의 사항으로 틀린 것은?

- ① 주요정보통신기반시설 보호계획의 조정에 관한 사항
- ② 주요정보통신기반시설 보호와 관련된 법 제정에 관한 사항
- ③ 주요정보통신기반시설 지정 및 지정 취소에 관한 사항
- ④ 주요정보통신기반시설 보호와 관련된 주요 정책 사항으로서 위원장이 회의에 부치는 사항

84. 다음 중 위험식별 및 평가를 위한 위험평가 방법으로 틀린 것은?

- ① 베이스라인 접근법 ② 자산 분석법
- ③ 상세 위험 분석법 ④ 복합 접근법

85. 다음 중 조직의 위험분석 및 평가와 관련한 설명으로 틀린 것은?

- ① 위험평가 방법론은 조직의 특성에 맞게 자체적으로 정하여 적용할 수 있으나 위험평가의 과정은 합리적이어서 하고 위험평가 결과는 실질적인 위험의 심각성을 대변하여야 한다.
- ② 조직의 위험평가 수행 시 외부의 보안 컨설턴트 등 전문가를 필수적으로 참여시켜야 한다.
- ③ 위험식별 및 평가 시행을 위한 예산 계획을 매년 수립하고 정보보호 최고책임자 등 경영진의 승인을 받아야 한다.
- ④ 위험평가는 연 1회 이상 정기적으로 수행하되 조직의 변화, 신규시스템 도입 등 중요한 사유가 발생한 경우 해당 부분에 대하여 정기적인 위험평가 이외에 별도로 위험평가를 수행하여야 한다.

86. 디지털포렌식 과정 중 수집된 디지털 증거를 이송, 분석, 보관, 법정 제출 등 각 단계에서 담당자 및 책임자를 명확히 함으로써 증거물의 진정성을 판단하는 중요한 기준을 지칭하는 원칙은?

- ① 관리 연속성 ② 전문 배제성
- ③ 독수 독과성 ④ 증거 무결성

87. 다음 물리적 보호대책 구현 중 출입통제에 대한 설명으로 틀린 것은?

- ① 보호구역별로 허가된 자만이 출입할 수 있도록 내·외부자 출입통제 절차를 마련하고 출입 가능한 인원현황을 관리하여야 한다.
- ② 보호구역별로 출입 가능한 부서·직무·업무를 정의하며, 출입 권한이 부여된 임직원을 식별하고 그 현황을 관리하여야 한다.
- ③ 각 보호구역에 대한 내·외부자 출입 기록을 일정기간 보존하고 출입 기록 및 출입 권한을 주기적으로 검토하여야 한다.
- ④ 시스템적으로 출입 로그를 남길 수 없는 경우 출입 통제 장치만 설치하여도 된다.

88. 다음 중 외부자 보안에 대한 설명으로 틀린 것은?

- ① 업무의 일부를 외부에 위탁하거나 외부의 시설 또는 서비스를 이용하는 경우, 그 현황을 식별하고 법적 요구 사항 및 외부 조직과 서비스로부터 발생하는 위험을 파악하여 적절한 보호 대책을 마련하여야 한다.
- ② 외부 서비스를 이용하거나 외부자에게 업무를 위탁하는 경우 이에 따른 정보보호 및 개인정보보호 요구 사항을 식별하고 관련 내용을 계약서 또는 협정서 등에 명시하여야 한다.
- ③ 계약서, 협정서, 내부정책에 명시된 정보보호 및 개인정보보호 요구 사항에 따라 외부자의 보호 대책 이행 여부는 주기적인 점검 또는 감사 등 관리·감독하지 않아도 된다.
- ④ 외부자 계약만료, 업무종료, 담당자 변경 시에는 제공한 정보자산 반납, 정보시스템 접근 계정 삭제, 중요정보 파기, 업무 수행 중 취득정보의 비밀 유지 약속서 징구 등의 보호 대책을 이행하여야 한다.

89. 다음 중 정보보안제품의 보안기능 요구사항 계층 구조에 대한 설명으로 틀린 것은?

- ① 클래스 - 동일 보안목적은 가지는 패밀리들의 집합
- ② 패밀리 - 동일 보안목적이나 보안 강도 또는 제약사항이 다른 컴포넌트들의 집합
- ③ 컴포넌트 - 보호프로파일 또는 보안목표명세서에서 선택 가능한 최대 단위
- ④ 엘리먼트 - 보안기능을 세부적으로 표현할 수 있는 단위

90. 다음 중 정보보호 및 개인정보보호 관리체계(ISMS-P) 인증 심사원에 대한 설명으로 틀린 것은?

- ① 인증심사원의 자격 유효기간은 자격을 부여받은 날로부터 3년이다.
- ② 심사원보 자격 취득 후 인증심사에 4회 이상 참여하고 심사 일수의 합이 20일 이상이 되면 심사원 자격을 획득할 수 있다.
- ③ 인증심사원의 자격발급 및 관리는 금융분야는 금융보안원, 그 외의 분야는 한국인터넷진흥원에서 수행한다.
- ④ 인증심사원으로서 객관적이고 공정한 인증심사를 수행하지 않는 경우 심사원 자격을 취소할 수 있다.

91. 정보통신서비스제공자의 지휘·감독을 받아 이용자의 개인정보를 처리하는 역할을 수행하는 개인정보취급자의 역할 및 책임 사항으로 틀린 것은?

- ① 내부관리계획 등 각종 규정, 지침 등 준수
- ② 개인정보처리시스템의 안전한 운영 및 관리
- ③ 개인정보보호 교육 계획 수립 및 시행
- ④ 개인정보 침해사고 발생 시 대응 및 보고

92. 정보통신기반 보호법에서 주요정보통신기반시설의 보호에 관한 사항을 심의하기 위하여 정보통신기반보호위원회를 구성하도록 규정하고 있다. 다음 중 정보통신기반보호위원회에 대한 설명으로 옳은 것은?

- ① 주요정보통신기반시설의 보호에 관한 사항을 심의하기 위하여 대통령산하에 정보통신기반보호위원회를 둔다.
- ② 정보통신기반보호위원회의 위원은 위원장 1인을 포함한 20인 이내의 위원으로 구성한다.
- ③ 위원회의 위원장은 국무총리가 되고 위원회의 위원은 대통령이 정하는 중앙행정기관의 차관급 공무원과 위원장이 위촉하는 자로 한다.
- ④ 정보통신기반보호위원회의 효율적인 운영을 위하여 위원회에 공공분야와 민간분야를 각각 담당하는 실무위원회를 둔다.

93. 다음 문장에서 설명하는 용어로 적합한 것은?

국가안전보장, 행정, 국방, 치안, 금융, 통신, 운송, 에너지 등의 업무와 관련된 전자적 제어·관리시스템

- ① 개인정보처리시스템 ② 정보보안 관리시스템
- ③ 정보통신기반시설 ④ 출입통제시스템

94. 개인정보보호법 안정성확보조치기준에 따라 개인정보처리자는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 1년 이상 보관·관리하여야 한다. 이때 기록해야 하는 항목으로 틀린 것은?

- ① 개인정보를 처리한 계정 ② 마지막 로그아웃 시간
- ③ 수행한 업무의 내용 ④ 처리한 정보주체의 정보

95. 다음 중 개인정보와 프라이버시에 대한 설명으로 옳은 것은?

- ① 개인정보는 자기 자신에 전속한 권리로서 누구의 간섭도 받지 않고 독립적으로 그 권리를 행사할 수 있으나 프라이버시는 실질적으로 수집, 관리하고 있는 기관의 권리도 인정한다.
- ② 프라이버시는 정보, 신체, 지역, 금융, 사회적 프라이버시 다섯 가지로 분류된다.
- ③ 프라이버시는 인격권 그 자체이지만 개인정보는 인격권의 침해가 없더라도 보호해야 할 경우가 있다.
- ④ 개인정보와 프라이버시에 대한 보호제도는 혼재된 것이 아닌 완전히 다른 개념이다.

96. 정보통신망 이용촉진 및 정보보호에 관한 법률 시행령 제36조의 7 (정보보호 최고책임자의 지정 및 겸직금지 등)에 규정되어 있는 정보보호 최고책임자의 자격 요건으로 올바르게 정의한 것은?

- ① 정보보호 또는 정보기술 분야의 국내 또는 외국의 학사학위 이상 학위를 취득한 자
- ② 정보보호 또는 정보기술 분야의 국내 또는 외국의 석사학위 이상 학위를 취득한 자
- ③ 정보보호 또는 정보기술 분야의 국내 또는 외국의 학사학위 이상 학위를 취득 및 정보보호 또는 정보기술 분야의 5년 이상 경력자
- ④ 정보보호 또는 정보기술 분야의 국내 또는 외국의 전문학사학위 이상 학위를 취득 및 정보보호 또는 정보기술 분야의 10년 이상 경력자

97. 다음 중 위험관리 절차의 순서를 올바르게 나열한 것은?

- ㉠ 자산 식별
- ㉡ 식별된 위험에 대한 정보보호대책 선정
- ㉢ 위험평가
- ㉣ 위험분석
- ㉤ 위험 감시 및 재검토

- ① ㉠ - ㉡ - ㉢ - ㉣ - ㉤ ② ㉠ - ㉣ - ㉢ - ㉡ - ㉤
- ③ ㉠ - ㉡ - ㉣ - ㉢ - ㉤ ④ ㉠ - ㉣ - ㉡ - ㉢ - ㉤

98. 시스템 침해사고 발생에 따라 디지털 포렌식을 진행할 때 다음 명령어로 확인할 수 있는 것은?

- net start
- sc query

- ① 동작 프로세스 행위 분석 ② 시스템 주요 경로 무결성 점검
- ③ 서비스 시작과 서비스 확인 ④ 시스템 정보 확인

99. 다음 중 업무용 단말기기 보안에 대한 설명으로 틀린 것은?

- ① 업무용 단말기기에 대하여 기기 인증, 승인, 접근범위 설정, 기기 보안 설정 등의 보안 통제 정책을 수립·이행해야 한다.
- ② 자료공유프로그램 사용 금지, 공유설정 제한, 무선망 이용 통제 등 개인정보 및 중요정보가 유출되는 것을 방지하기 위한 정책을 수립·이행해야 한다.
- ③ 업무용 단말기기에 대한 접근통제 대책의 적절성에 대하여 점검하지 않아도 된다.
- ④ 업무용 단말기기의 분실, 도난 등으로 인한 개인정보 및 중요정보의 유·노출을 방지하기 위하여 비밀번호 설정 등의 보안 정책을 적용하여야 한다.

100. 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위한 설명으로 틀린 것은?

- ① 개인정보처리시스템의 Session Timeout을 설정해야 한다.
- ② Session Timeout 설정값은 업무상 필요한 최소한의 시간으로 적용해야 한다.
- ③ 개인정보 취급자의 업무용 컴퓨터 화면보호기 설정을 통해서도 가능하다.
- ④ 일정시간 이상 업무처리를 하지 않아 개인정보처리시스템에 접속이 차단된 이후 다시 접속하고자 할 때도 최초의 로그인과 동일한 방법으로 접속하여야 한다.